Hacking con Metasploit

Relazione personale dell'attività svolta in laboratorio

Scopo della pratica

In questa pratica ho lavorato su Metasploitable per analizzare il servizio FTP vsftpd 2.3.4 e seguire i passaggi indicati nella traccia. Ho iniziato verificando la rete e l'indirizzo IP del target; successivamente ho usato Nmap per identificare il servizio, ho consultato il modulo dedicato in Metasploit e ho raccolto le evidenze dei test eseguiti. La traccia chiedeva inoltre di creare la directory /test_metasploit nella radice di Metasploitable. Ho riportato nella relazione ciò che ho effettivamente osservato, distinguendo i risultati confermati da quelli che non sono riuscito a confermare.

Preparazione dell'ambiente e indirizzi IP

Per seguire l'indirizzo indicato nella traccia ho configurato Metasploitable con IP statico 192.168.1.149/24. Su Kali era già presente l'indirizzo 192.168.50.100/24; per raggiungere il target nella rete richiesta ho aggiunto anche 192.168.1.100/24 all'interfaccia eth0. Ho scelto di non modificare pfSense, come concordato durante il lavoro.

Sistema/interfaccia	Indirizzo osservato	Descrizione
Kali Linux — eth0	192.168.50.100/24	Indirizzo già presente
Kali Linux — eth0, indirizzo aggiuntivo	192.168.1.100/24	Usato per la rete del target
Metasploitable — eth0	192.168.1.149/24	Indirizzo richiesto dalla traccia
pfSense LAN	192.168.50.1/24	Lasciata invariata
pfSense OPT1	192.168.60.1/24	Lasciata invariata

Controllo della connettività

Dopo aver configurato gli indirizzi, da Kali ho eseguito un ping verso 192.168.1.149. Nel terminale ho visto 4 pacchetti trasmessi e 4 ricevuti, con 0% di perdita. Questo mi ha confermato che Kali riusciva a raggiungere Metasploitable sulla rete di laboratorio.

Scansione Nmap e identificazione del servizio

Ho eseguito una scansione Nmap con rilevamento delle versioni. Il risultato mostrava la porta 21/tcp aperta e il servizio FTP identificato come vsftpd 2.3.4. La scansione più ampia mostrava anche altri servizi attivi sulla macchina, ma per questa pratica mi sono concentrato sul servizio FTP indicato nella consegna. La versione rilevata è compatibile con quella oggetto dell'esercitazione; da sola, però, non dimostra che un tentativo di exploit avrà necessariamente successo.

Esame del modulo in Metasploit

In Metasploit ho selezionato il modulo exploit/unix/ftp/vsftpd_234_backdoor. Ho consultato le opzioni con show options e ho impostato il target RHOSTS su 192.168.1.149. Per il test era indicata la porta FTP 21. Ho usato anche il comando edit, come previsto dalla parte facoltativa, per leggere il codice del modulo, e successivamente info per consultare la descrizione, i target disponibili e i riferimenti.

Nel codice ho osservato che il controllo preliminare verifica il servizio FTP e cerca indizi associati alla versione 2.3.4, oltre a controllare la porta 6200. Eseguendo check, Metasploit ha riportato che il banner suggeriva una possibile vulnerabilità e che la backdoor poteva essere presente. Ho quindi considerato questo risultato come un'indicazione preliminare, non come una conferma definitiva.

Prove effettuate con Telnet e Netcat

Per osservare direttamente il servizio FTP ho usato Netcat sulla porta 21. Il server ha risposto con il banner 220 (vsFTPd 2.3.4). Ho provato anche a collegarmi con Telnet: il server ha richiesto una password dopo il comando USER, ma la connessione è terminata con un timeout. Non considero quindi quel tentativo un login FTP riuscito.

In un altro test Nmap ha indicato la porta TCP 6200 come aperta. Collegandomi con Netcat a 192.168.1.149 sulla porta 6200, ho ricevuto la risposta uid=0(root) gid=0(root), seguita da output relativo al sistema e alle interfacce di rete. Ho salvato lo screenshot perché è un'evidenza rilevante del comportamento osservato nel laboratorio. Nonostante questo risultato, quando ho controllato sessions -l in Metasploit, il programma ha mostrato No active sessions. Perciò non posso affermare di aver ottenuto una sessione registrata da Metasploit.

Creazione della directory /test_metasploit

Quando ho provato a digitare mkdir /test_metasploit dal prompt del modulo Metasploit, il terminale ha restituito Permission denied. In seguito ho capito che quel comando non stava creando la directory sul sistema bersaglio. Sono passato alla console di Metasploitable e ho verificato di essere l'utente msfadmin. Il tentativo diretto di creare la directory nella radice è stato rifiutato perché l'utente non aveva i permessi di scrittura in /. Con sudo -l ho verificato che il mio account poteva utilizzare sudo; ho quindi eseguito sudo mkdir -p /test_metasploit.

Infine ho eseguito ls -ld /test_metasploit. L'output mostrava la directory presente, con proprietario root e gruppo root. Questo conferma che ho completato il requisito della cartella sul sistema Metasploitable. Preciso però che l'ho creata dalla console locale usando sudo, non attraverso una sessione dell'exploit registrata in Metasploit.

Riepilogo dei risultati

Attività	**Esito**	**Nota**
Configurazione IP	Completata	Target configurato come richiesto
Connettività	Completata	Ping 4/4, nessuna perdita
Rilevamento di vsftpd 2.3.4	Completato	Nmap ha rilevato la porta 21 aperta
Analisi del modulo con edit e info	Completata	Codice e informazioni consultati
Comando check	Esito preliminare positivo	Il modulo indica che la backdoor potrebbe essere presente
Test Telnet/Netcat	Parziale	Banner FTP osservato; Telnet non ha completato il login
Porta 6200	Risposta osservata	Netcat ha mostrato uid=0(root)
Directory /test_metasploit	Completata	Creata con sudo e verificata con ls -ld
Sessional Metasploit	Non confermata	sessions -l ha mostrato

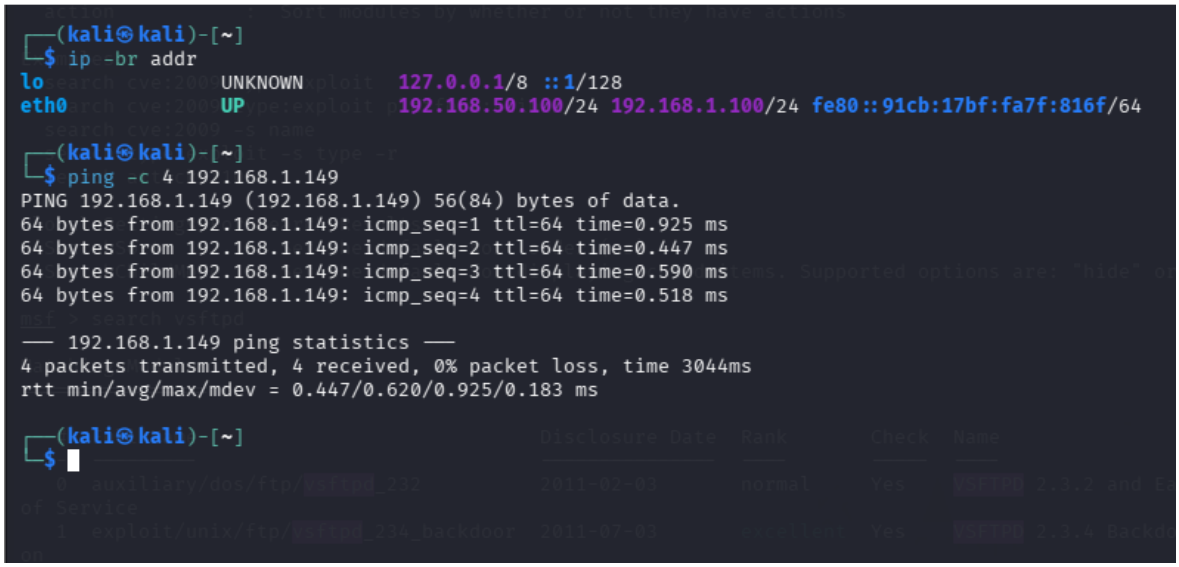
		No active sessions

Considerazioni finali

Durante questa pratica ho imparato a controllare la connettività tra le macchine virtuali, a identificare un servizio con Nmap e a leggere le informazioni e il codice di un modulo Metasploit. Ho anche capito che un risultato preliminare di check non equivale alla conferma di una sessione e che bisogna prestare attenzione al terminale in cui si esegue un comando. Sono riuscito a creare e verificare /test_metasploit sul target, ma non ho documentato una sessione attiva registrata da Metasploit. Per questo considero completati i passaggi di configurazione, analisi e creazione della directory, mentre il requisito della sessione rimane non confermato.

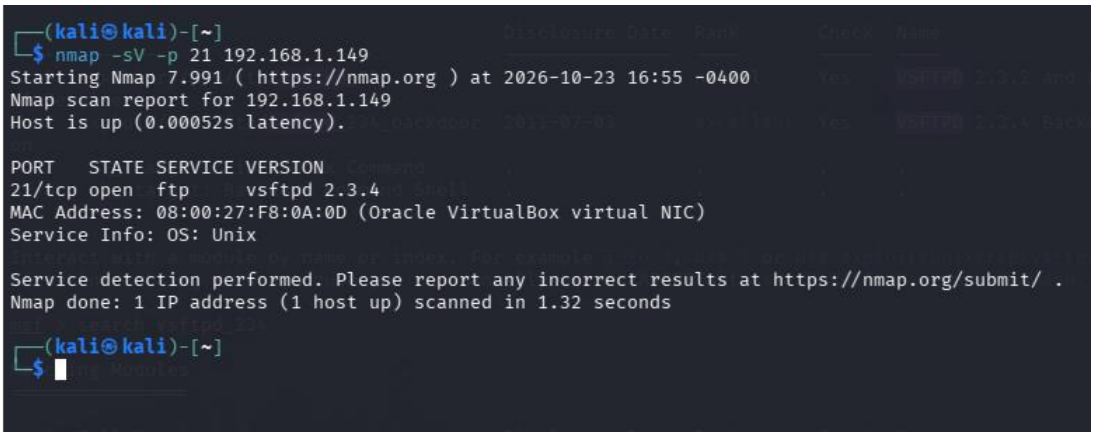
Screenshot e spiegazione dei passaggi

Ho inserito sotto ogni passaggio lo screenshot corrispondente, seguito da una spiegazione in prima persona di quello che ho fatto e di quello che si vede nel terminale. Le figure sono state selezionate in base ai file disponibili e ai risultati condivisi durante la pratica.Configurazione e connettività da Kali



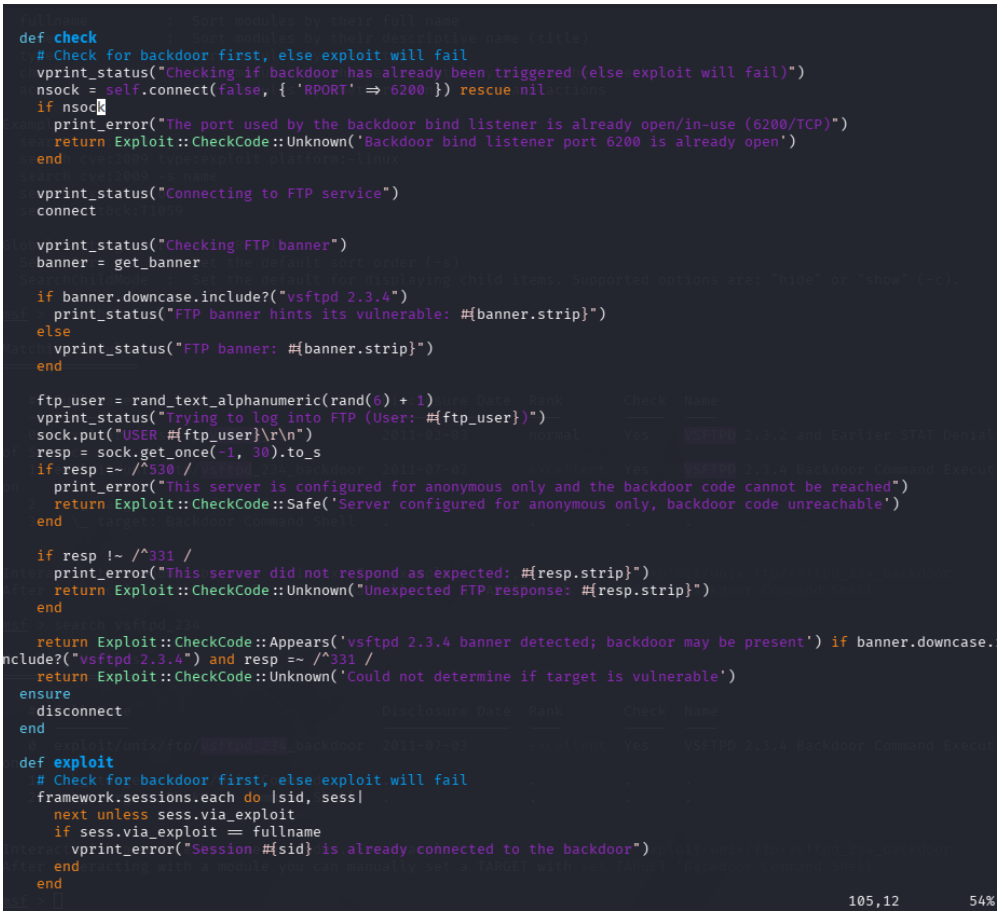
In questa schermata ho controllato gli indirizzi di Kali e ho eseguito il ping verso 192.168.1.149. La risposta di tutti e quattro i pacchetti mi ha confermato che il target era raggiungibile.

Rilevamento del servizio FTP con Nmap



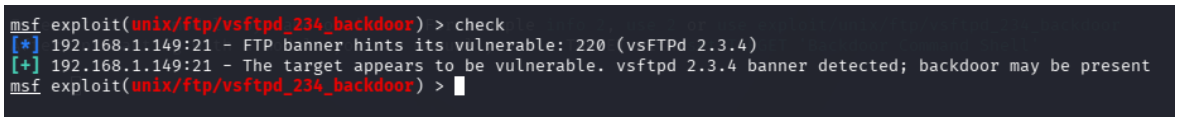
Qui ho usato Nmap con il rilevamento delle versioni. Il risultato mostra la porta 21/tcp aperta e vsftpd 2.3.4, il servizio su cui si concentra la pratica.

Codice del modulo consultato con edit



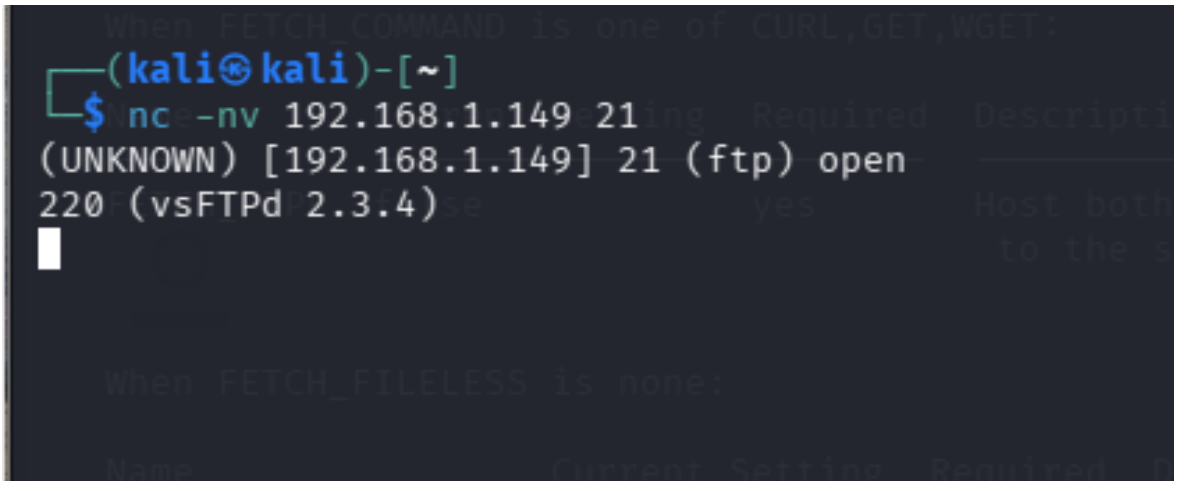
Ho aperto il codice del modulo per vedere come viene effettuato il controllo preliminare. La funzione check cerca indizi nel banner FTP e controlla anche la porta associata alla backdoor.

Risultato del comando check



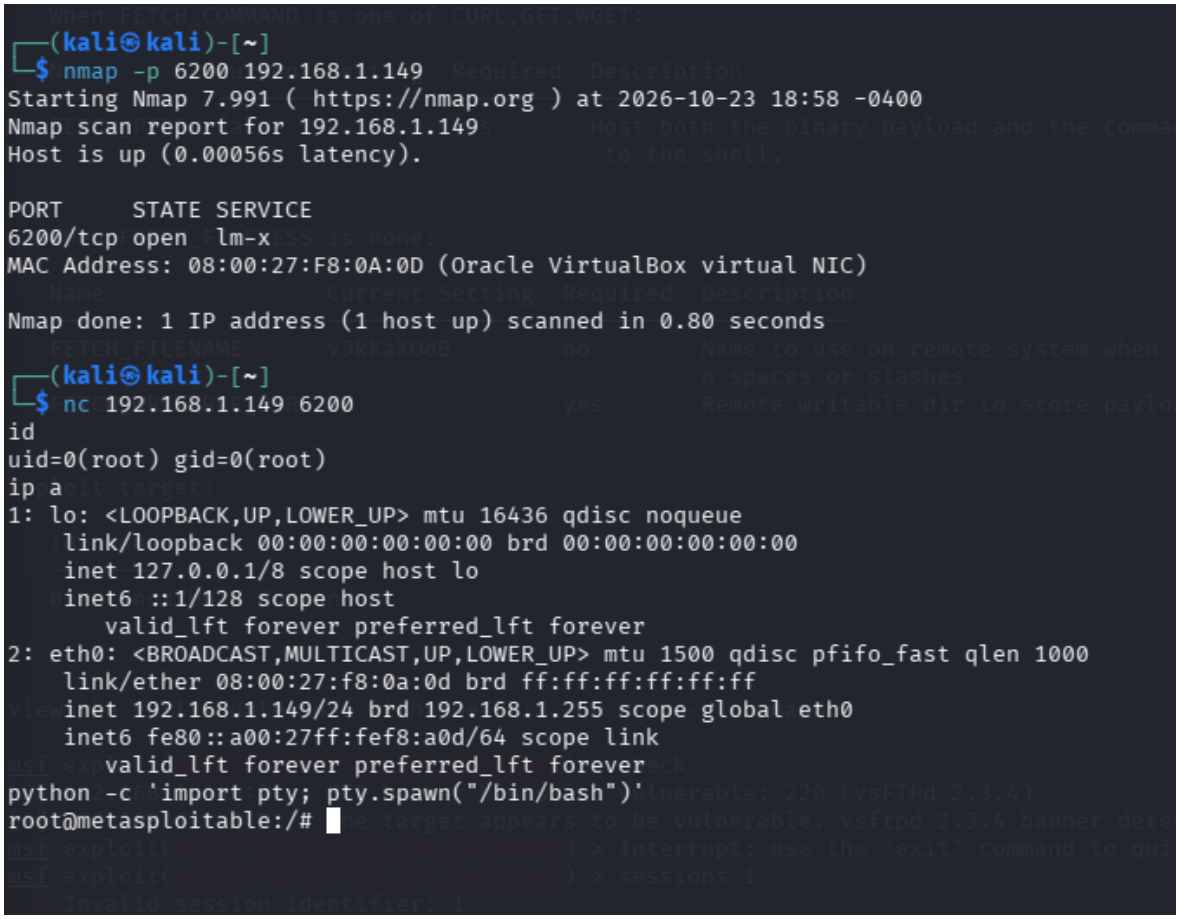
In questa schermata Metasploit segnala che il banner di vsftpd 2.3.4 è compatibile con una possibile vulnerabilità. Ho registrato il risultato come indicazione preliminare, senza considerarlo una prova definitiva.

Connessione al servizio FTP con Netcat



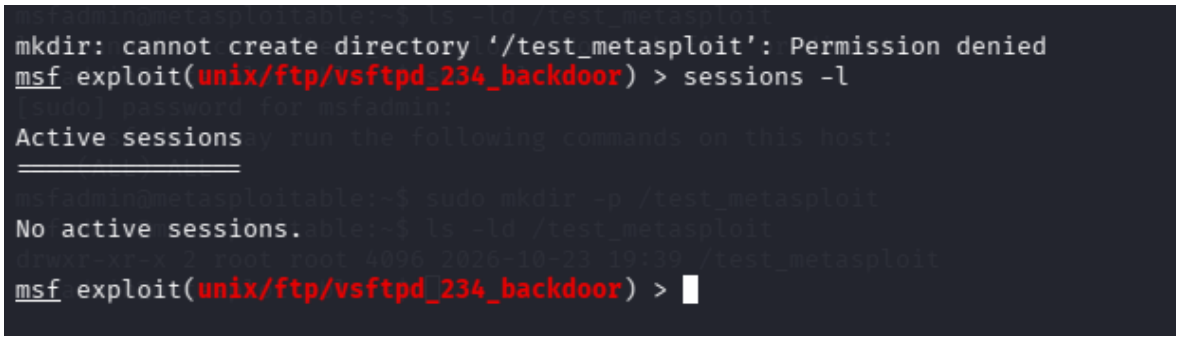
Ho usato Netcat per collegarmi alla porta 21 e leggere la risposta del servizio. Il banner 220 conferma che il servizio FTP risponde e dichiara vsftpd 2.3.4.

Verifica della porta 6200



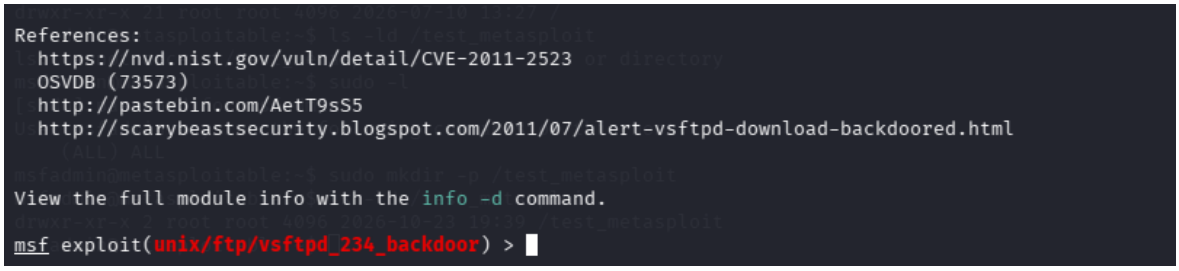
In questa schermata Nmap rileva la porta 6200 aperta e la connessione Netcat restituisce uid=0(root). È un risultato importante del test, ma non coincide con una sessione registrata da Metasploit.

Controllo delle sessioni Metasploit



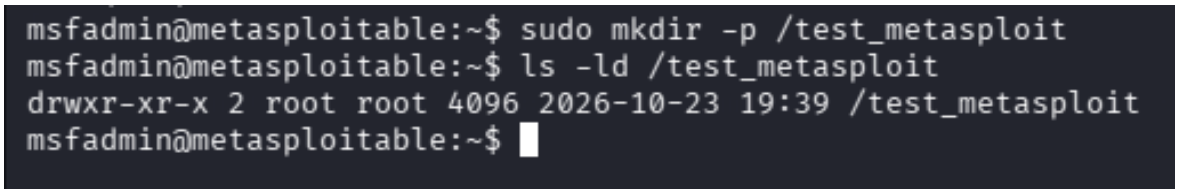
Ho eseguito sessions -l per verificare se Metasploit avesse registrato una sessione. L'output No active sessions indica che non ne risultavano di attive in quel momento.

Informazioni del modulo con info



Ho consultato le informazioni del modulo. La schermata mostra il nome VSFTPD 2.3.4 Backdoor Command Execution, la piattaforma Unix/Linux, i target disponibili e le opzioni di base.

Verifica della directory sul target



Dalla console di Metasploitable ho creato la directory con sudo e poi ne ho verificato l'esistenza con ls -ld. L'output mostra /test_metasploit con proprietario root e gruppo root.